UNIVERSITY OF LONDON

BSc EXAMINATION 2025

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3612: CRITICAL INFRASTRUCTURE SECURITY

Time Allowed: **TWO** hours

Attempt **three** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

© Royal Holloway University of London 2025

Question 1 Infrastructure Network Models

Many (critical) infrastructure networks can be modelled in the form of graphs, which may then be further augmented e.g. with edge weights denoting the capacity of a link.

(a) Consider the case of the Internet as a global critical infrastructure.

(i) Why is it necessary to model both the physical interconnectivity of the Internet and the logical structure when aiming to understand the vulnerability of the Internet to attacks? Give a brief, reasoned answer. [7]

(ii) The large-scale logical structure of the Internet is constructed through the Border Gateway Protocol (BGP) at the level of Autonomous Systems (AS). This protocol is policy-based and hence requires explicit decisions to connect to other AS.

Why does the large-scale structure of the Internet follow a power-law degree distribution given that individual connections are made mostly deliberately? Give a brief, reasoned answer. [8]

(b) Power networks can be represented as sparse graphs with edge weights as noted above.

If an attacker is able to remove a small number of transmission lines (i.e. edges from the graph) in order to deny adequate power to a region (i.e. component of the graph): Which algorithm(s) can the attacker use to determine the minimal number of lines to be cut in order to do so?

Give a reasoned answer; it is not necessary to demonstrate the working of the algorithm(s) chosen. [10]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Threat and Adversary Modelling

Threat actors will increasingly be able to rely on automation for generating attacks, including more complex multi-stage attacks. This will at least call into question how effective a risk-based approach focusing on individual attack vectors can be.

(a) Using a common framework such as the MITRE ATT&CK (Enterprise) matrix, give a brief overview of how an adversary will seek to achieve an objective (e.g. to place a remote access toolkit in critical systems) of a victim enterprise, dealing with security measures along the way in a multi-stage attack. [10]

(b) For the attack described in question 2(a), construct an Attack Countermeasure Tree (ACT), identifying at least one countermeasure available to the defender for each stage of the attack.

Identify how the use of independent security controls affect the ability to perform the attack based on an analysis of the ACT you have constructed, and justify this reasoning. [10]

(c) Game-theoretical models can be used to understand the interactions between attacker and defender. For the attack modelled in question 2(a) and 2(b), identify and justify the type of game-theoretical model most appropriate to help the attacker understand what the optimal attack strategy may be. [5]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 Cyber Physical Systems Security

A wastewater treatment plant (see figure 1 for a diagrammatic overview) operates on relatively slow time-scales, but must cope with varying demand as well as environmental parameters such as precipitation and temperature as well as variations in the composition of the wastewater in its control system. As the processes controlled by the industrial control system (ICS) will be too slow to be implemented reactively, the control system will depend on prediction based on data found in the data historian.

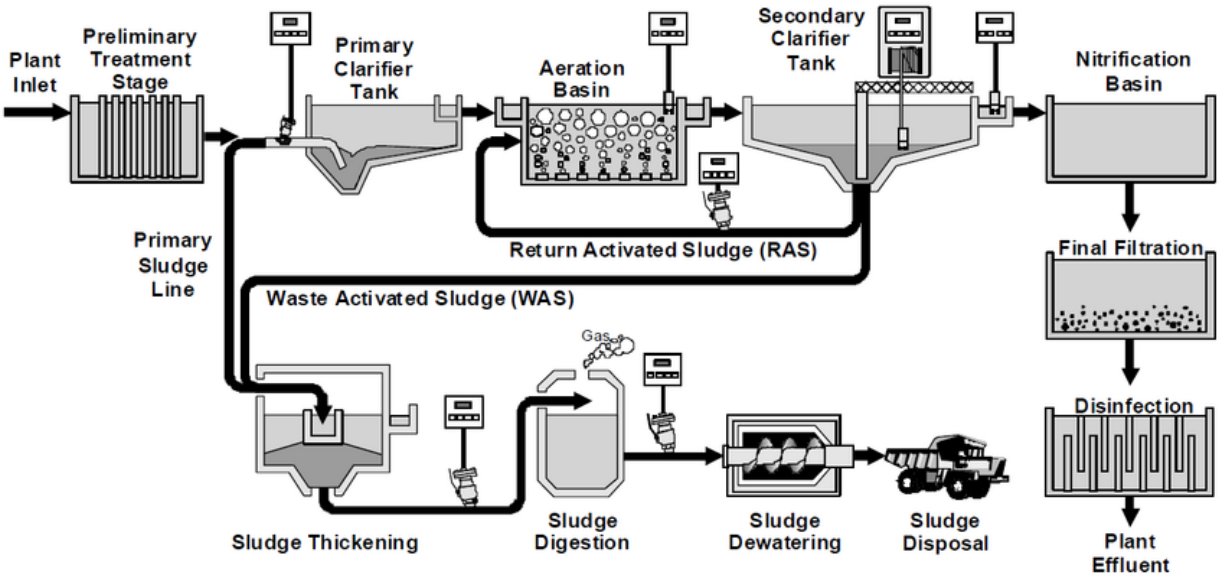

Figure 1: Typical Wastewater Treatment Plant

(a) Will it be sufficient for an attacker to change values in the data historian to cause the plant's operation to degrade or fail? Give a brief, reasoned answer; it may be helpful to provide a diagram for this purpose. [12]

(b) The water treatment control process described above relies on sensor readings and actuators in locations spread over a larger area, and where physical access control to facilities may be limited.

Assume that sensors (e.g. nitrate levels) and actuators (e.g. pumps and valves) are controlled using protocol such as Modbus over an wireless

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

network with functional security settings including confidentiality, integrity, and authentication based on IEEE 802.11i, 802.11s and 802.11w.

How can an adversary able to physically *observe* the plant behaviour interfere with the behaviour of the plant, if no physical access is possible, but if the wireless network traffic can be *observed and interfered with*?

Give a reasoned answer for how such an attack would be conducted and why it should be effective. [13]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Network Infrastructure Security

While the global routing structure of the Internet based on the Border Gateway Protocol (BGP) is not hierarchical, some aspects of the Internet infrastructure incorporate hierarchies.

(a) The domain name system (DNS) is a hierarchical system in which the namespace is iteratively delegated from a set of global top-level domains (gTLD) controlled by a multilateral body, the Internet Corporation for Assigned Names and Numbers (ICANN), headquartered in the United States, which also operates the DNS root zone registries.

(i) What (technical) consequences would arise if the name space authority for a country's top-level domain (e.g. `.uk`) were to be delegated to a not-too-friendly entity?

Identify two activities that such an entity can undertake besides outright refusal to resolve the TLD. [6]

(ii) To avoid spoofing and tracking, several encrypted DNS mechanisms have been proposed including DNS-over-HTTPS (DoH, IETF RFC 8484).

This relays DNS queries over HTTPS, but requires trust in the DoH servers (e.g. in the case of Microsoft Windows 11, these would be by default one of Cloudflare, Google, or Quad9).

Would DoH be more or less resilient to denial of service attacks than the conventional DNS protocol for a given client? Give a brief, reasoned answer. [6]

(b) Basic BGP-4 is susceptible to *hijacking* attacks in which attackers claim to originate a prefix, but also to *deflection* attacks in which a path between AS is (temporarily) re-directed through other networks (AS).

(i) Consider a deflection attack in which the traffic from a UK payment processor in a UK-based AS that would ordinarily be routed to an AS in North America to reach its parent company's systems is temporarily routed through an AS located in the Russian Federation.

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Would the use of Resource Public Key Infrastructure (RPKI, RFC 8210) allow to detect or defend against such an attack? Give a brief, reasoned answer. [6]

(ii) RPKI requires that Route Origin Authorisations (ROAs) for prefixes are authenticated using a hierarchy of keys that trace the delegation structure from ICANN through Regional Internet Registries (RIRs).

Identify the consequences of not being able to validate signatures on ROAs for a given prefix, and describe how an attacker may achieve this through denial of service attacks. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Cyber Conflict and Policy

Whilst international law still considers wars to commence upon declaration of hostilities, conflicts are found along a spectrum with cyber means forming an important element of such hybrid warfare, although very similar means may also be employed for intelligence-gathering activities that are not conventionally considered to be an element of conflict.

(a) Many subversion attacks rely on very similar toolkits and functionality in that they contain an obfuscation mechanism ("root kits") and remote administration tools (RATs) in order to control or exfiltrate target systems.

If the security services of a country discover such tools in the operational parts of a critical infrastructure such as power networks, should this be treated differently to finding similar tools in management systems of the same infrastructure? Give a reasoned answer. [12]

(b) One of the characteristics of hybrid warfare is the reliance on intermediaries such as criminal groups to conduct deniable operations.

(i) If a non-state actor causes severe harm (e.g. by shutting down the UK 999 emergency call services with a ransomware attack) and claims that this was done accidentally, but intelligence services are able to find indicators of a state actor having encouraged such activities, what may be a response that the targeted nation state (in this case the UK) can undertake? Give a reasoned answer. [6]

(ii) State-adjacent actors need not operate in the same jurisdiction as the state sponsoring (or "encouraging") their activities.

Consider the case of the attack in question 5(b)(i), but where this attack originates from the territory of an allied nation and the network of an operator based in the allied nation. In which way would the response discussed in your answer to question 5(b)(i) change under these circumstances? Give a rationale. [7]

END

Stephen Wolthusen

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.